МІНІСТЕРСТВО ОСВІТИ І НАУКИ УКРАЇНИ

НАЦІОНАЛЬНИЙ ТЕХНІЧНИЙ УНІВЕРСИТЕТ УКРАЇНИ
«КИЇВСЬКИЙ ПОЛІТЕХНІЧНИЙ ІНСТИТУТ імені ІГОРЯ СІКОРСЬКОГО»

Навчально-науковий фізико-технічний інститут

Кафедра інформаційної безпеки

ЗВІТ

з дисципліни «Кіберзахист об’єктів критичної інфраструктури»

Лабораторна робота № 5. Вдосконалення недоліків протоколів інтернету речей

Варіант 4 (парний): Modbus v3.1.6

Виконав: Вовкотруб Олександр Віталійович
Група: ФБ-61мн

Перевірив: Войцеховський А. В.

Київ 2026

Зміст

1 Мета роботи **2**

2 Постановка задачі **2**

3 Теоретичні відомості **2**

3.1 Протокол Modbus і його вразливості 2

3.2 Засоби усунення й обґрунтування вибору 3

4 Хід виконання **3**

4.1 Реалізація 3

4.2 Параметри захищеного з’єднання 4

5 Результати сніфінгу **4**

6 Активні атаки на канал зв’язку **5**

7 Ціна захисту **6**

8 Аналіз результатів **7**

9 Відповіді на контрольні питання **7**

10 Висновки **8**

11 Перелік джерел **8**

1 Мета роботи

Ознайомитися з недоліками протоколів пристроїв інтернету речей, що є частиною об’єктів критичної інфраструктури, і типовими програмними рішеннями з їх усунення. На прикладі протоколу Modbus впровадити криптографічний захист засобами бібліотеки OpenSSL і показати його дієвість за допомогою сніфера.

2 Постановка задачі

Згідно з варіантом (парний, Modbus v3.1.6):

1. проаналізувати вразливості протоколу Modbus;
2. запропонувати й обґрунтувати криптографічні засоби захисту;
3. реалізувати захищену взаємодію «клієнт-сервер» засобами OpenSSL;
4. показати дієвість захисту за допомогою сніфера, що перехоплює пакети, - порівняти трафік до та після впровадження захисту.

3 Теоретичні відомості

3.1 Протокол Modbus і його вразливості

Modbus, протокол прикладного рівня для промислової автоматизації (релейний захист, програмно-логічні контролери). Працює за моделлю «ведучий-ведений» (master-slave) з транзакціями «запит-відповідь». Основою є пакет PDU (Protocol Data Unit): однобайтовий код функції (1…127) і поле даних. Для передачі PDU загортається в ADU; у версії Modbus TCP перед PDU додається заголовок MBAP (ID транзакції, ID протоколу, довжина, адреса пристрою), а поле контрольної суми відсутнє (цілісність покладено на TCP).

Головні вразливості базового Modbus:

- **відсутність автентифікації**, сервер виконує будь-який коректно сформований запит, не перевіряючи, від кого він;
- **відсутність шифрування**, дані (коди функцій, адреси й значення регістрів) передаються у відкритому вигляді;
- **відсутність контролю цілісності** на рівні протоколу, немає підпису чи імітовставки, тому дані можна непомітно підмінити (атака «людина посередині», MITM).

Наслідок для об’єкта критичної інфраструктури: зловмисник, що має доступ до каналу зв’язку, може зчитувати технологічні параметри (розвідка) та підміняти команди й уставки контролерів, що безпосередньо загрожує технологічному процесу.

3.2 Засоби усунення й обґрунтування вибору

Оскільки сам Modbus не має механізмів безпеки, захист реалізують на транспортному рівні, загортаючи з'єднання в **TLS** (цей підхід стандартизовано як *Modbus/TCP Security* специфікацією Modbus Organization). TLS одразу закриває всі три вразливості:

- **конфіденційність**, симетричне шифрування корисного навантаження;
- **цілісність і автентичність повідомлень**, режим AEAD (вбудована імітовставка) виявляє будь-яку підміну;
- **автентифікація сторін**, за допомогою цифрових сертифікатів X.509, перевірених довіреним центром сертифікації (CA).

Вибір криптографічних примітивів (їх узгоджує TLS 1.3):

- **TLS 1.3** як мінімальна версія, прибрано застарілі й небезпечні набори шифрів, обов'язковий режим AEAD, швидше рукостискання (1-RTT);
- **ECDHE** (обмін ключами на еліптичних кривих з ефемерними ключами) - забезпечує *пряму секретність* (perfect forward secrecy): компрометація довгострокового ключа не розкриває раніше перехоплений трафік;
- **AES-256-GCM**, автентифікований симетричний шифр (AEAD): одночасно шифрування й контроль цілісності;
- **ECDSA на кривій P-256** для ключів сертифікатів, короткі ключі й швидке підписування, що важливо для обмежених ресурсів ПЛК;
- **автентифікація сервера за сертифікатом**, підписаним власним центром сертифікації об'єкта; клієнт відхиляє з'єднання, якщо сертифікат не підтверджено (захист від MITM).

4 Хід виконання

4.1 Реалізація

Реалізовано мінімальний Modbus TCP клієнт і сервер мовою C (`src/modbus_tcp.c`), що підтримують функцію 0x03 (Read Holding Registers) за специфікацією Modbus Application Protocol v1.1b3. Прапорець `--tls` загортає той самий прикладний обмін у TLS 1.3 засобами OpenSSL, не змінюючи логіку Modbus; завдяки цьому порівняння «до/після» коректне. Ввід-вивід абстраговано: функції `conn_read`/`conn_write` працюють або зі звичайним сокетом, або через `SSL_read`/`SSL_write`.

Сертифікати створено скриптом `gen-certs.sh`: власний кореневий CA (ECDSA P-256) і підписаний ним сертифікат сервера з ім'ям `plc.local` і SAN на 127.0.0.1. Клієнт перевіряє сертифікат сервера за `ca.crt` (`SSL_VERIFY_PEER`) і розриває з'єднання, якщо перевірка не пройшла.

Для перехоплення трафіку використано прозорий TCP-проксі-сніфер (`src/sniffer.py`), що моделює зловмисника на шляху «клієнт-сервер»: він пересилає байти між сторонами й

друкує їх у форматі hex. Такий сніфер бачить рівно те, що передається каналом (апаратний сніфер типу Wireshark у середовищі без прав на захоплення пакетів недоступний, тому застосовано проксі; результат для вмісту пакетів ідентичний). Обидва сценарії відтворюються скриптом `run.sh`.

4.2 Параметри захищеного з'єднання

Перевірка з'єднання (`openssl s_client`):

```
Protocol  : TLSv1.3
Cipher    : TLS_AES_256_GCM_SHA384
subject=  C=UA, O=Water Utility OKI, CN=plc.local
issuer=   C=UA, O=Water Utility OKI, CN=OKI Modbus CA
Verify return code: 0 (ok)
```

З'єднання використовує TLS 1.3 з AES-256-GCM, сертифікат сервера підтверджено ланцюжком до нашого CA.

5 Результати сніфінгу

Клієнт в обох сценаріях читає 4 регістри від адреси 0; сервер повертає значення 1000…1003. Перехоплений трафік наведено на рис. 5.1.

До захисту (відкритий Modbus TCP): сніфер бачить PDU і значення регістрів

```
[C->S] 12 байт
C->S 0000  00 01 00 00 00 06 01 03 00 00 00 04              ............
[S->C] 17 байт
S->C 0000  00 01 00 00 00 0b 01 03 08 03 e8 03 e9 03 ea 03  ................
S->C 0010  eb                                               .
```

Після захисту (Modbus через TLS 1.3): сніфер бачить лише шифротекст

```
[C->S] 1464 байт
C->S 0000  16 03 01 05 b3 01 00 05 af 03 03 46 99 72 83 cd  ...........F.r..
C->S 0010  7b 99 fb f7 1e 3e 9b bf b2 eb 58 77 ba 31 59 9a  {....>....Xw.1Y.
C->S 0020  98 fe 7f bc b5 16 3d 99 bb 84 bf 20 08 d9 4e 5a  ......=.... ..NZ
C->S 0030  f9 51 0d 48 86 5e be d9 1d 2c 09 2a 9e 17 0d 2c  .Q.H.^...,.*...,
C->S 0040  46 8a 98 5f 7a a4 bd a1 1d 06 c3 87 00 08 13 02  F.._z...........
C->S 0050  13 03 13 01 13 04 01 00 05 5e 00 0b 00 04 03 00  .........^......
C->S 0060  01 02 00 0a 00 1c 00 1a 11 ec 11 eb 11 ed 00 1d  ................
C->S 0070  00 17 00 1e 00 19 00 18 01 00 01 01 01 02 01 03  ................
C->S 0080  01 04 00 23 00 00 00 16 00 00 00 17 00 00 00 0d  ...#............
C->S 0090  00 24 00 22 09 04 09 05 09 06 04 03 05 03 06 03  .$."............
C->S 00a0  08 07 08 08 08 09 08 0a 08 0b 08 04 08 05 08 06  ................
C->S 00b0  04 01 05 01 06 01 00 2b 00 03 02 03 04 00 2d 00  .......+......-.
C->S 00c0  02 01 01 00 33 04 ea 04 e8 11 ec 04 c0 24 8c 24  ....3........$.
```

Рисунок 5.1. Трафік, перехоплений сніфером, до та після впровадження TLS

До захисту весь обмін читається у відкритому вигляді:

- запит `C->S: 00 01 00 00 00 06 01 03 00 00 00 04`, MBAP (ID транзакції `0001`, протокол `0000`, довжина `0006`, пристрій `01`) і PDU (код функції `03` = читання регістрів, початкова адреса `0000`, кількість `0004`);
- відповідь `S->C: ... 01 03 08 03 e8 03 e9 03 ea 03 eb`, код функції `03`, 8 байтів даних і значення регістрів `03 e8`…`03 eb`, тобто 1000…1003.

Зловмисник бачить і команду, і технологічні значення, і може їх підмінити.

Після захисту у трафіку видно лише рукостискання TLS і зашифровані записи. Автоматична перевірка перехоплених дампів підтверджує, що відкриті дані зникли (табл. 5.1).

Таблиця 5.1. Наявність відкритих даних Modbus у перехопленому трафіку

Шукана послідовність	До захисту	Після TLS
PDU запиту `01 03 00 00 00 04`	присутня	відсутня
Значення регістрів `03 e8 03 e9` (1000, 1001)	присутня	відсутня
Записи TLS (типи 16/14/17)	немає	ClientHello, ServerHello, ChangeCipherSpec, 11 записів Application Data (`17 03 03`)

Отже, після впровадження TLS сніфер не отримує жодної корисної інформації: ні команд, ні значень регістрів, ні можливості їх непомітно підмінити.

6 Активні атаки на канал зв’язку

Пасивне спостереження доводить лише втрату читабельності трафіку, тому сніфер доповнено трьома активними атаками (режими `--flip`, `--replay` та окремий підробний сервер). Режим `--flip` підробляє один байт у запиті клієнта (молодший байт початкової адреси регістрів 0 -> 8, тобто команда «читати регістри 0…3» перетворюється на «читати 8…11»); режим `--replay` після першої відповіді повторно надсилає серверу перехоплений запит.

Підміна команд. У відкритому Modbus атака вдається повністю: сервер виконує підроблену команду, і клієнт отримує значення регістрів 1008…1011 замість замовлених 1000…1003 (`data/client-plain-flip.txt`), тобто зловмисник непомітно керує тим, що читає (а в разі функції запису й тим, що виконує) контролер. У TLS той самий напад призводить до негайного розриву: сервер виявляє невідповідність імітовставки AEAD і надсилає попередження `bad record mac` (SSL alert 20), клієнт завершує роботу з помилкою (`data/client-tls-flip.txt`).

Повторне відтворення. Для відкритого Modbus повторений запит є законним запитом: сервер виконує його ще раз, і клієнт приймає дублікат відповіді (17 неочікуваних байтів з тими самими значеннями регістрів, `data/client-plain-replay.txt`). У TLS повторно надісланий запис Application Data відхиляється: номери записів уже витрачені, сервер розриває з'єднання, і клієнт не отримує нічого (`data/client-tls-replay.txt`).

Підробний сервер. Клієнт, що перевіряє сертифікат, відмовляється від з'єднання з сервером, сертифікат якого не підписано довіреним CA (`certificate verify failed`, `data/client-evil-server.txt`); без цієї перевірки саме так працювала би атака «людина посередині».

Таблиця 5.2. Результати активних атак до та після впровадження TLS

Атака	Відкритий Modbus	Modbus через TLS 1.3
Підміна байта команди	виконується непомітно (клієнт отримує інші регістри)	відхиляється, попередження `bad record mac`
Повторне відтворення запиту	виконується, клієнт отримує дублікат відповіді	відхиляється, сервер розриває з'єднання
Підробний сервер (невірний CA)	можливий (автентифікації немає)	клієнт відмовляється від з'єднання

7 Ціна захисту

Витрати на захист виміряно на 200 послідовних з'єднаниях по 20 запитів через проксі-сніфер на локальному вузлі (`--bench`, `data/bench.txt`).

Таблиця 5.3. Середній час встановлення з'єднання та запиту

Показник	Відкритий Modbus	Modbus через TLS 1.3
З'єднання з рукостисканням, мс	0,026	1,13
Запит-відповідь, мс	0,020	2,10

Рукостискання TLS 1.3 коштує близько 1 мс, а шифрування запису підіймає час обміну з ~0,02 до ~2 мс, тобто на два порядки в абсолютних величинах. Однак у реальному циклі опитування ПЛК (десятки-сотні мілісекунд) ці витрати непомітні, а рукостискання оплачується один раз на сесію; для обмежених контролерів частину навантаження можна перенести на прозорий шлюз. Отже, аргумент «TLS задорогий для ОТ» у цьому сценарії не підтверджується.

8 Аналіз результатів

Порівняння показує, що TLS усуває всі три вразливості базового Modbus (табл. 5.4), причому активні атаки (табл. 5.2) доводять це безпосередньо, а не лише наявністю шифротексту в дампі.

Таблиця 5.4. Властивості Modbus до та після захисту

Властивість	Базовий Modbus	Modbus через TLS 1.3
Конфіденційність	немає (відкритий текст)	AES-256-GCM
Цілісність повідомлень	немає (лише TCP)	AEAD (виявляє підміну)
Автентифікація сторін	немає	сертифікати X.509 + CA
Пряма секретність	немає	ECDHE

Ціна захисту виміряно безпосередньо (табл. 5.3): близько 1 мс на рукостискання і ~2 мс на запит, що непомітно в реальному циклі опитування. Для багатьох застарілих ПЛК, що не підтримують TLS, захист реалізують «прозорим шлюзом» (termination proxy) перед пристроєм. Варто зауважити обмеження: TLS із автентифікацією лише сервера не захищає від зловмисника, що видає себе за довірений клієнт, тому для команд запису специфікація Modbus/TCP Security передбачає взаємну автентифікацію (mTLS); повна модель загроз вимагає також сегментації мережі та контролю доступу (IEC 62443).

9 Відповіді на контрольні питання

1. Які вразливості має протокол Modbus. У базовому варіанті відсутні автентифікація сторін і шифрування; дані (коди функцій, адреси й значення регістрів) передаються у відкритому вигляді; немає контролю цілісності на рівні протоколу (у Modbus TCP немає навіть контрольної суми). Це уможливлює сніфінг, підміну команд і даних (MITM), несанкціоновані запити до контролерів, а також атаки повторного відтворення (replay). Додатково: функція читання/запису будь-яких регістрів без обмеження прав і відсутність захисту від перевантаження запитами (DoS).

2. Які засоби усунення вразливостей варто використовувати у більшості протоколів інтернету речей OKI. Основою є криптографічний захист каналу: шифрування корисного навантаження (симетричні AEAD-шифри, напр. AES-GCM), контроль цілісності (імітовставки HMAC або вбудовані в AEAD), автентифікація сторін за цифровими сертифікатами (X.509, PKI) або попередньо розподіленими ключами, обмін ключами з прямою секретністю (ECDHE), захист від повторного відтворення (лічильники, мітки часу, nonce). На практиці це реалізують стандартними протоколами, TLS/DTLS (для TCP/UDP), а для обмежених пристроїв відповідні профілі. Доповнюють їх організаційні й мережеві заходи: сегментація IT/OT, контроль доступу, оновлення прошивок, моніторинг трафіку (відповідно до IEC 62443).

10 Висновки

На прикладі протоколу Modbus впроваджено криптографічний захист засобами OpenSSL: той самий обмін Modbus TCP загорнуто в TLS 1.3 (AES-256-GCM, обмін ключами ECDHE, автентифікація сервера сертифікатом X.509, підписаним власним CA). Дієвість перевірено і пасивно, і активно: сніфер-зловмисник, що стоїть на шляху з'єднання, у відкритому режимі читав команди й значення регістрів у відкритому вигляді, а з активними атаками непомітно підміняв команду (клієнт отримав регістри 1008…1011 замість 1000…1003) і виконував повторне відтворення запитів (клієнт приймав дублікати відповідей). Після впровадження TLS усі три атаки провалилися: підміна виявляється імітовставкою AEAD (`bad record mac`), повторне відтворення відхиляється номерами записів, підробний сервер розпізнається перевіркою сертифіката, а в трафіку лишилися тільки рукостискання й зашифровані записи. Виміряна ціна захисту (~1 мс на рукостискання, ~2 мс на запит) непомітна в реальному циклі опитування ПЛК; для застарілих контролерів TLS впроваджують прозорим шлюзом, а для захисту від підробних клієнтів застосовують взаємну автентифікацію (mTLS, Modbus/TCP Security).

11 Перелік джерел

1. Modbus Organization. MODBUS Application Protocol Specification V1.1b3. 2012. URL: https://www.modbus.org/specs.php
2. Modbus Organization. MODBUS/TCP Security Protocol Specification. 2018.
3. libmodbus, A Modbus library (v3.1.6). URL: https://github.com/stephane/libmodbus
4. OpenSSL Project. OpenSSL 3.x Documentation. URL: https://www.openssl.org/docs/
5. Rescorla E. The Transport Layer Security (TLS) Protocol Version 1.3 : RFC 8446. IETF, 2018.
6. IEC 62443. Industrial communication networks. Network and system security.
7. Стьопочкіна І. В., Ільїн К. І., Овчарук М. В. Кіберзахист об'єктів критичної інфраструктури. Лабораторний практикум : навч. посіб. Київ : КПІ ім. Ігоря Сікорського, 2023. 59 с.